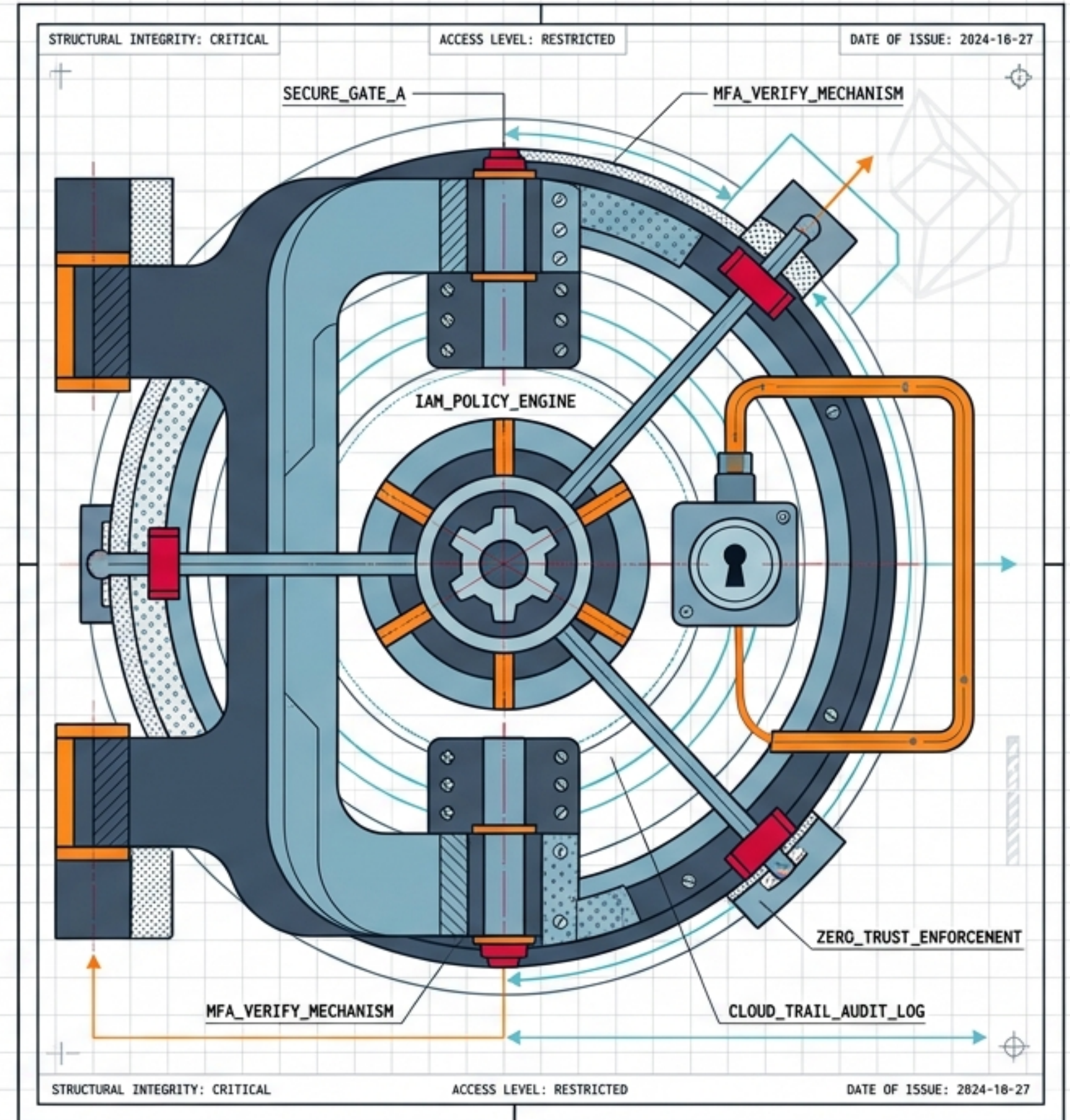


Architecting Access in AWS

A structural blueprint for Identity and Access Management (IAM), from fundamental mechanisms to enterprise-grade Zero Trust.

SEC_DOC_REF: IAM_01 // VERSION: LATEST



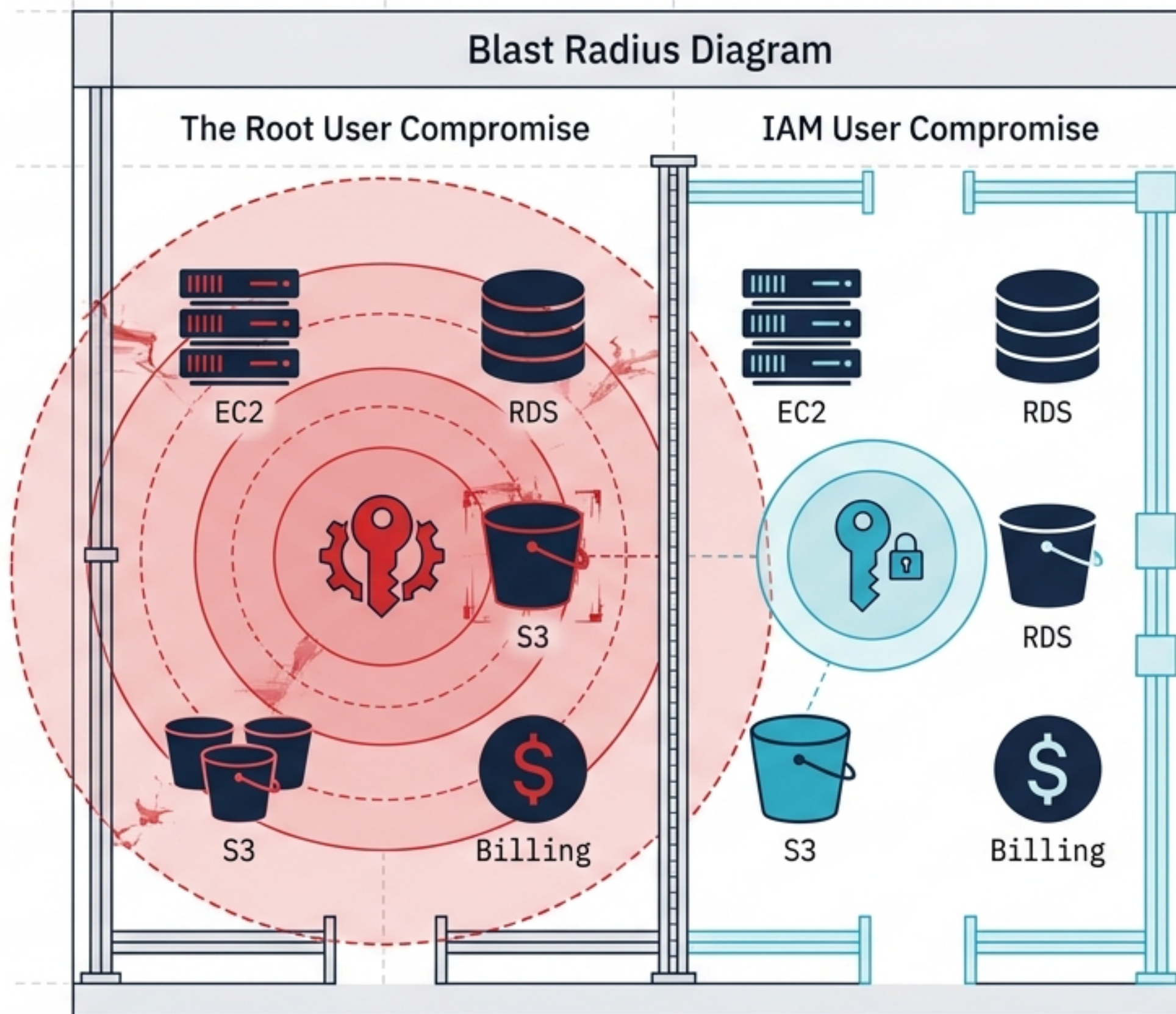
The Existential Threat of the Root User

Imagine a 1,000-employee company sharing one Root Account. One compromised password or accidental click can terminate databases, delete backups, and alter billing.

AWS Best Practice: Never use the Root User for daily work.

Exceptions (When to use Root):

- Closing the AWS account
- Changing support plans
- Restoring specific IAM permissions



The Dual Layers of Access Control

Authentication (AuthN)

Who are you?

- Validates identity
- Username & Password
- Multi-Factor Authentication (MFA)



Authorisation (AuthZ)

What are you allowed to do?

- Evaluates attached policies
- Dictates allowed actions (e.g., view, start, delete)
- Controls access to specific **AWS** resources



The Identity Matrix: Core IAM Components

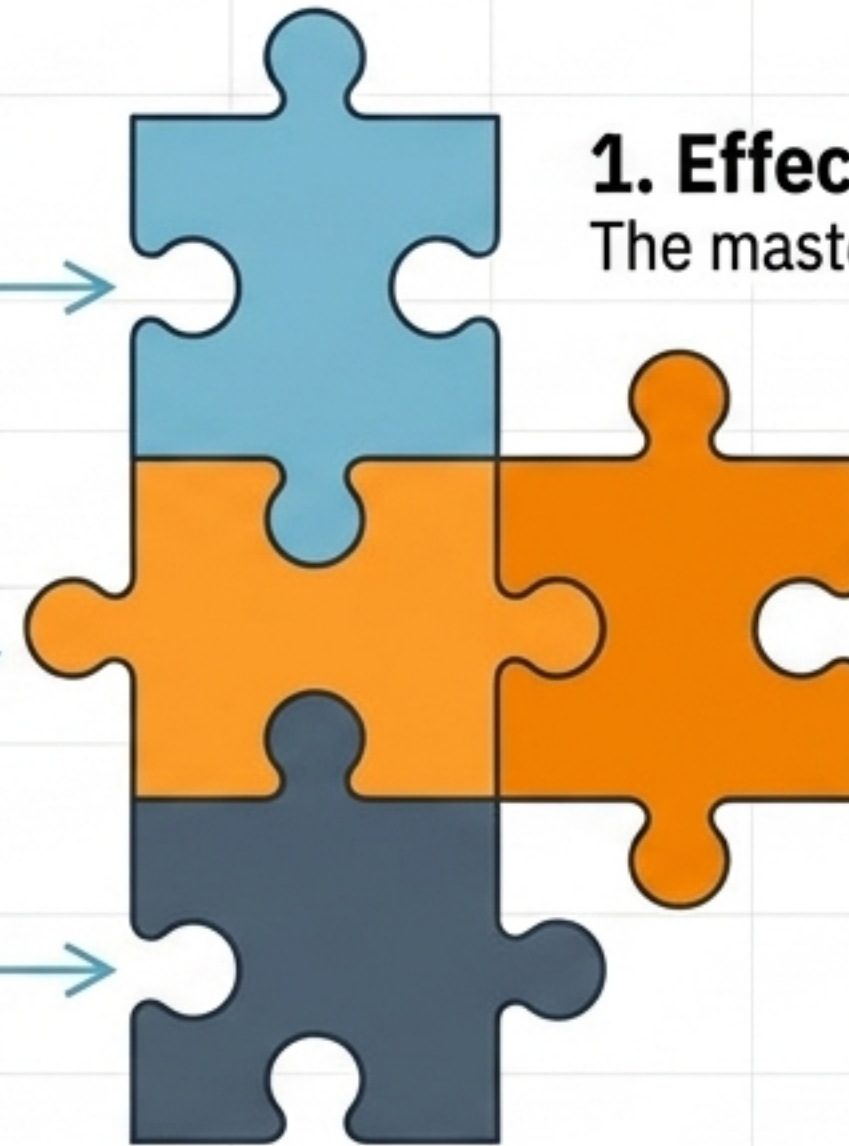
Component	Entity Type	Lifespan	Primary Use Case	Physical Analogy
IAM User	Individual Person or App	Long-term	Daily console or programmatic API access.	Employee ID Badge 
IAM Group	Collection of Users	Persistent	Scaling departmental permissions efficiently.	Department Master Key 
IAM Role	Temporary Identity	Short-term (Hours)	AWS services and cross-account access.	Temporary Visitor Pass 
IAM Policy	JSON Document	Persistent	Defining exact granular permissions.	The Security Rulebook 

Important: One IAM User = One Person.
Never share IAM users between employees.

Policies: The Digital Lock and Key

Policies are written in JSON, but they function as a simple interlocking logic system.

```
{
  Statement: [{
    Effect: Allow,
    Action: s3:GetObject,
    Resource: arn:aws:s3:::data/*
  }]
}
```



1. Effect (Allow/Deny)
The master switch.

2. Action
What is being done?
(e.g., ec2:StartInstances)

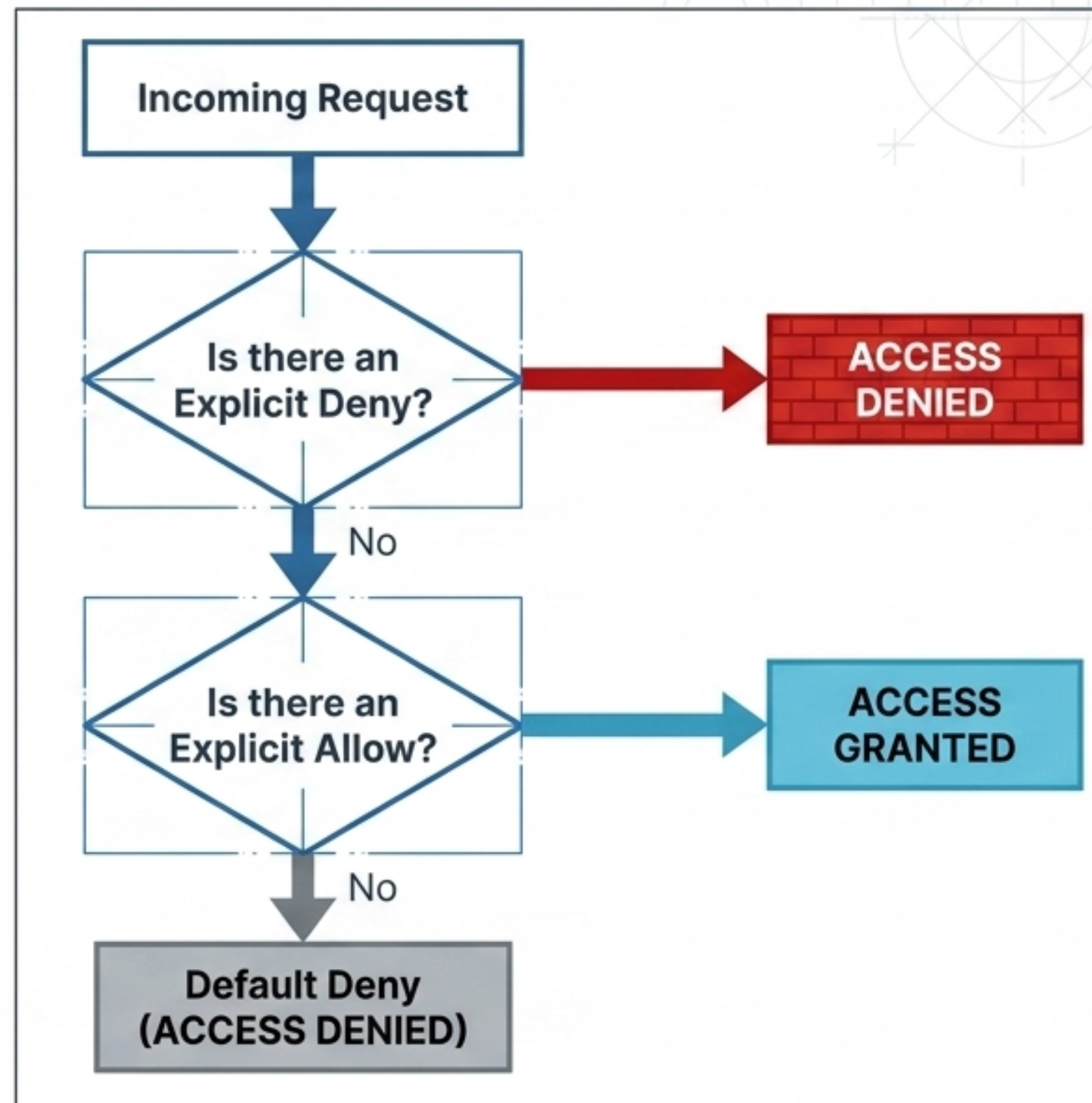
3. Resource
Where is it happening?
(The specific AWS asset)

Note: Policies can be AWS Managed (e.g., AdministratorAccess) or Customer Managed for custom organisational rules.

Policy Evaluation Logic

The Golden Rule: An explicit Deny ALWAYS overrides an explicit Allow.

1. Default state is always Deny.
2. AWS evaluates all attached policies.
3. If any policy states “Deny”, the request is blocked immediately.
4. Without an explicit “Allow”, the default deny remains in effect.



The Risk of Persistent Credentials

Console Access

Used for human interaction with the **AWS Management Console**.

Username & Password + Multi-Factor Authentication (MFA).



Programmatic Access

Used for APIs and Command Line Interfaces (CLI).

Access Key ID + Secret Access Key.

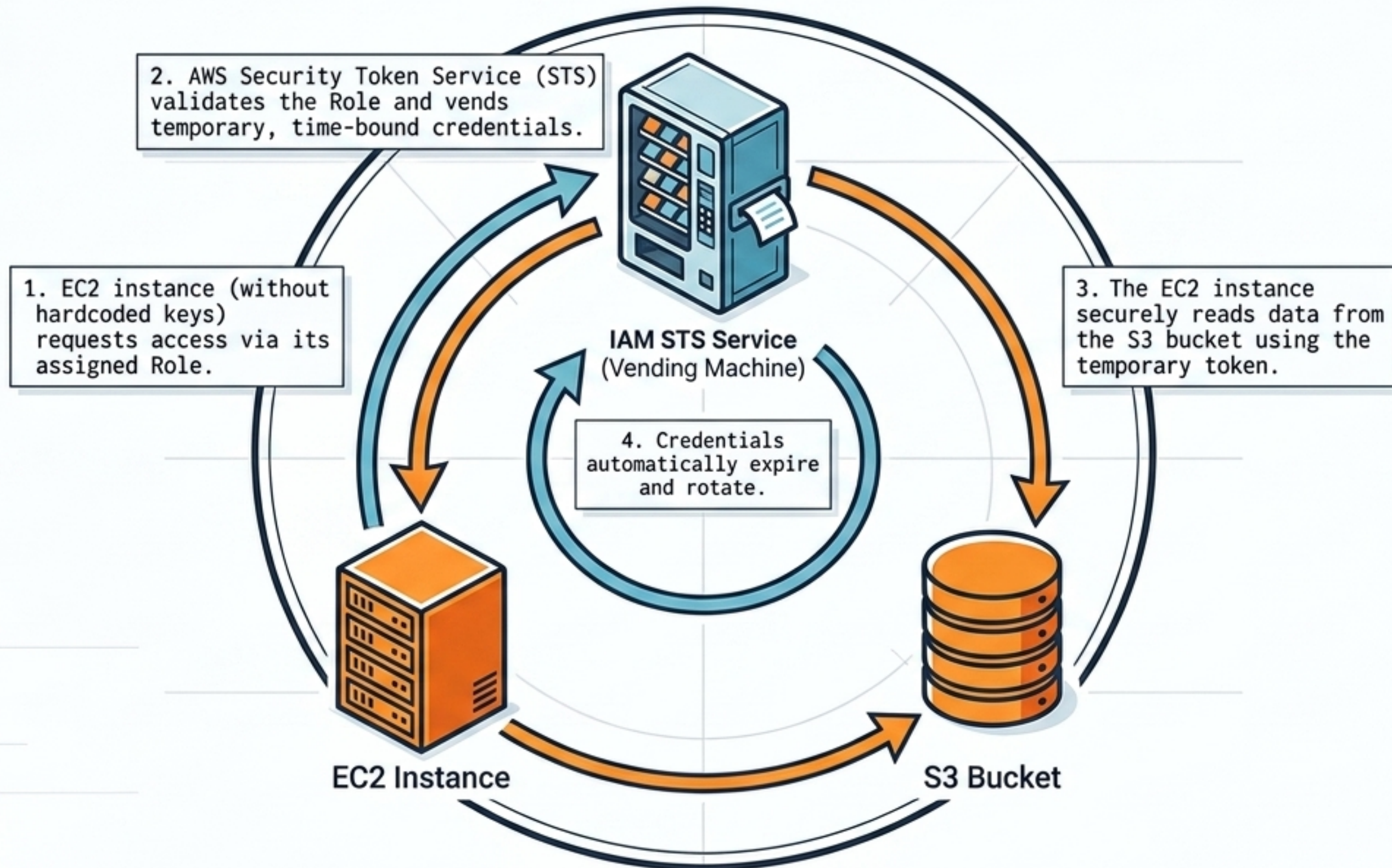


WARNING: Never hardcode access keys into applications or commit them to public repositories like GitHub.

If applications shouldn't use persistent keys, how do they access AWS securely?

IAM Roles: The Credential Vending Machine

Roles are assumed temporarily by applications, AWS services, or external users, eliminating the need for hardcoded passwords.

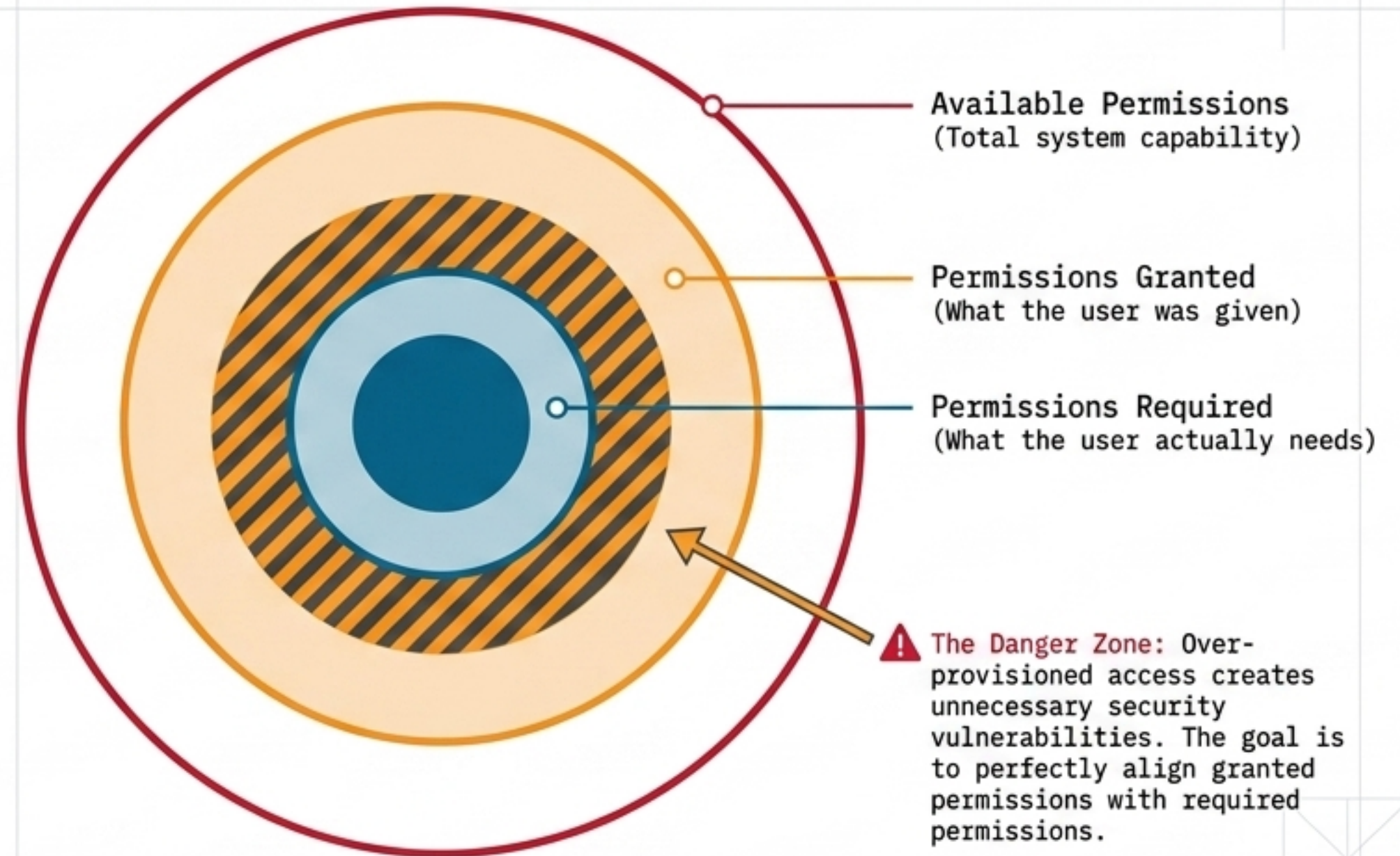


The Principle of Least Privilege

One of the most critical security practices in AWS.

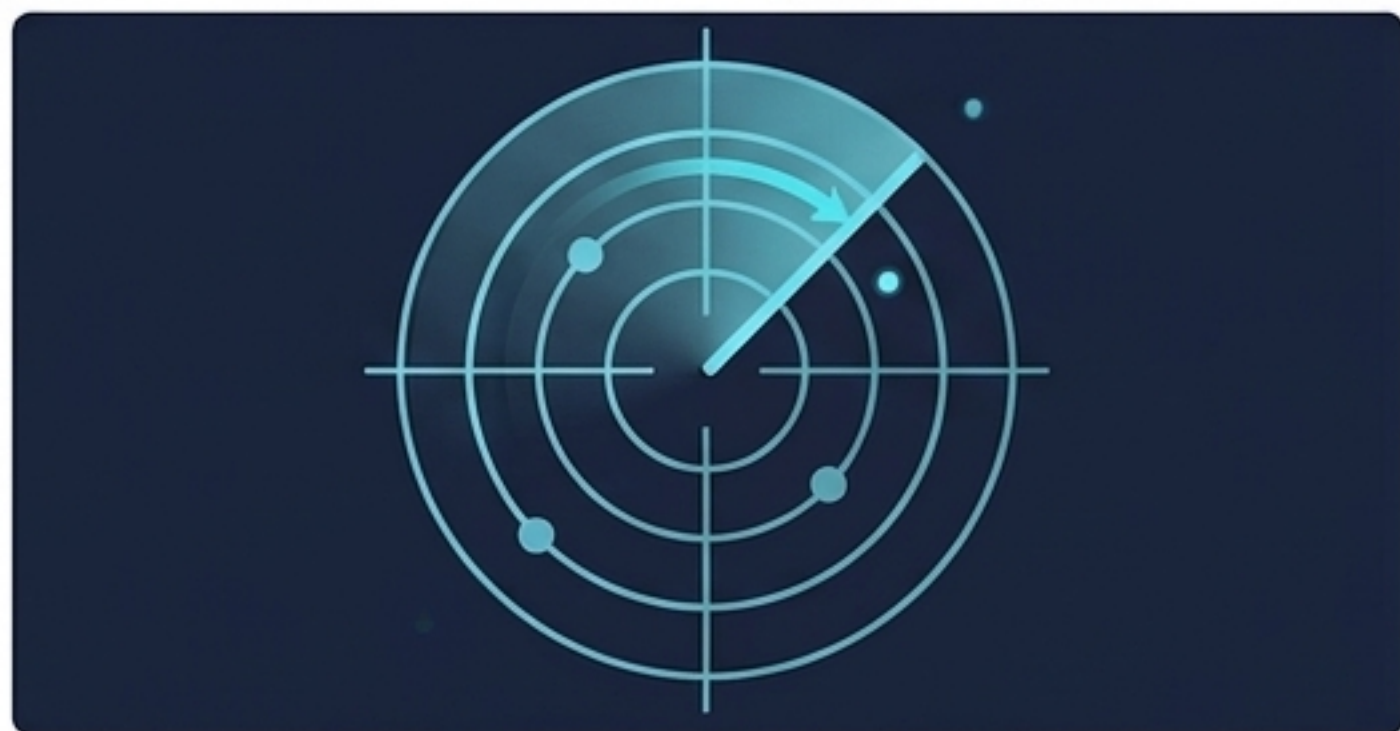
Always start with minimum permissions and explicitly add access only as required.

The Concentric Circles of Least Privilege



Continuous Auditing and Surveillance

MODULE 01: IAM Access Analyzer



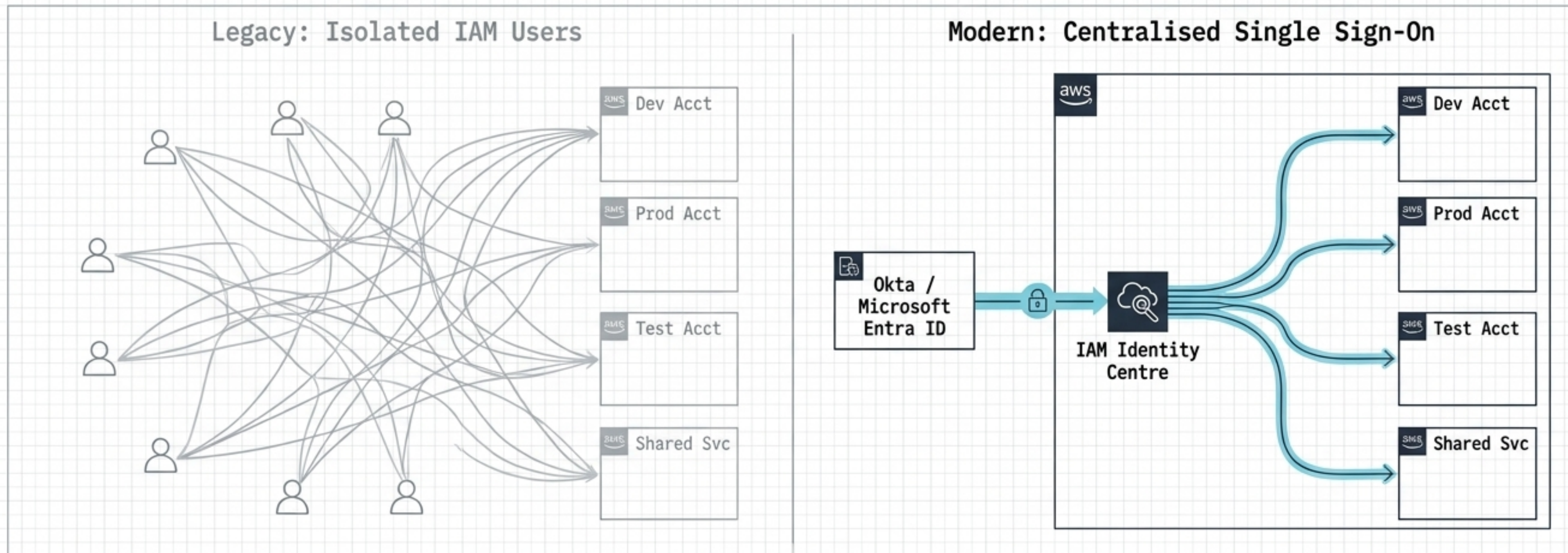
- **Function:** Uses automated reasoning to proactively analyse policies.
- **Detects:** Unintended public access, cross-account access, and overly permissive configurations.

MODULE 02: IAM Access Advisor



- **Function:** Tracks historical usage data for users and roles.
- **Detects:** Which services an entity has actually accessed (and when).
- **Purpose:** Crucial for pruning unused, legacy permissions to maintain Least Privilege.

The Modern Paradigm: Centralised Identity



IAM Identity Centre

The AWS-recommended solution for workforce access. Enables single sign-on (SSO), centralised management, and direct integration with corporate identity providers.

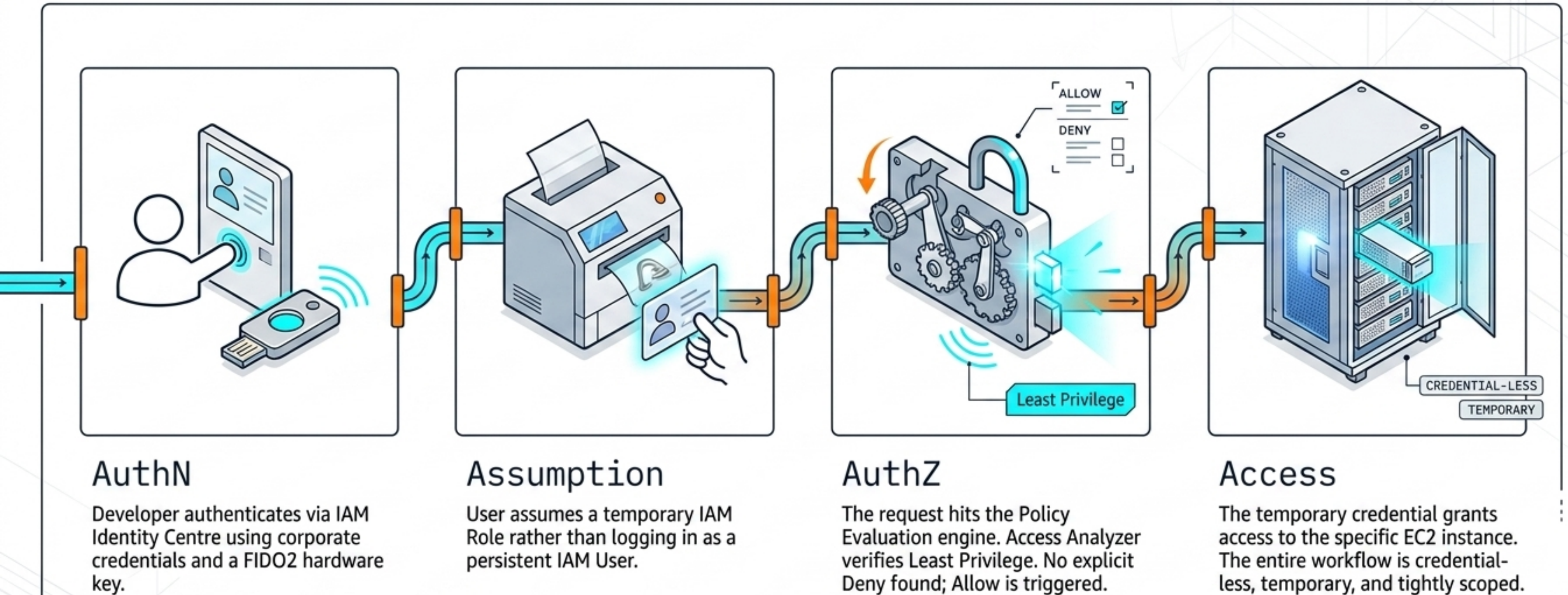
IAM Roles Anywhere

Allows workloads outside AWS (e.g., on-premises servers) to obtain secure, temporary credentials using X.509 certificates. Completely eliminates long-term access keys.

Authentication Upgrades

Mandatory hardware security keys (FIDO2/WebAuthn) rather than easily phishable passwords for Root and Administrative access.

The Modern Enterprise Architecture



END_TRANSMISSION // ARCHITECTURE SECURED